PRÁCTICA 3 - WEB SEGURO

Realizado por Unai García Blanco y Alberto García Martín

1. Instalación de un Servidor Web Seguro.

El objetivo de esta práctica es configurar un servidor Apache en Linux para operar de forma segura utilizando el protocolo HTTPS, el cual asegura la confidencialidad y autenticidad en la comunicación mediante el cifrado TLS. Para ello, se requiere la creación de una Autoridad de Certificación (CA) con OpenSSL que genere y firme certificados digitales.

PASO 1. CREACIÓN DE LA AUTORIDAD DE CERTIFICACIÓN.

Vamos a comenzar creando una autoridad de certificación (CA). Para ello, generamos las claves RSA pública y privada con el siguiente comando:

openssl genrsa -out key.pem 2048

Con ello almacenamos la clave privada en un archivo .pem

```
alber@alber-VirtualBox:~$ openssl genrsa -out key.pem 2048
alber@alber-VirtualBox:~$
```

y posteriormente un certificado X.509 autofirmado que va a contener la clave p pública correspondiente con:

openssl req -x509 -new -nodes -key key.pem -sha256 -days 3650 -out cert.pem

```
alber@alber-VirtualBox:~$ openssl req -x509 -new -nodes -key key.pem -sha256 -days 3650 -out cert.pem
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Salamanca
Locality Name (eg, city) []:Salamanca
Organization Name (eg, company) [Internet Widgits Pty Ltd]:SEGURIDAD DE SISTEMAS INFORMATICOS
Organizational Unit Name (eg, section) []:Practica 3 2024-2025
Common Name (e.g. server FQDN or YOUR name) []:Autoridad Cert Garcia_Martin_Garcia_Blanco
Email Address []:beetogm@usal.es
```

Especificaremos un certificado x.509 de 3650 días, es decir, 10 años. Este archivo cert.pem contendrá la clave pública de la CA.

PASO 2. CREACIÓN DE LA CERTIFICACIÓN DEL SERVIDOR.

Generamos un par de claves RSA (privada y pública) de 2048 bits para nuestro servidor:

openssl genrsa -out serverkey.pem 2048

Después generamos una solicitud de firma de certificado (CSR):

openssl req -new -key serverkey.pem -out servercsr.pem

```
alber@alber-VirtualBox:~$ openssl req -new -key serverkey.pem -out servercsr.pem
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Salamanca
Locality Name (eg, city) []:Salamanca
Organization Name (eg, company) [Internet Widgits Pty Ltd]:usal
Organizational Unit Name (eg, section) []:seguridad
Common Name (e.g. server FQDN or YOUR name) []:localhost
Email Address []:beetogm@usal.es

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:contra123%
An optional company name []:
```

Debemos de especificar el CN como ‘localhost’.

Ahora firmamos el archivo csr mediante la autorización de certificación creada previamente en el paso 1:

openssl x509 -req -in servercsr.pem -CA cert.pem -CAkey key.pem -CAcreateserial -out servercert.pem -days 3650 -sha256

```
alber@alber-VirtualBox:~$ openssl x509 -req -in servercsr.pem -CA cert.pem -CAkey key.
pem -CAcreateserial -out servercert.pem -days 3650 -sha256
Certificate request self-signature ok
subject=C = ES, ST = Salamanca, L = Salamanca, O = usal, OU = seguridad, CN = localhos
t, emailAddress = beetogm@usal.es
```

Vamos a verificar finalmente el estado del servidor para comprobar que se ha firmado correctamente:

openssl x509 -in servercert.pem -text -noout

```
alber@alber-VirtualBox:~$ openssl x509 -in servercert.pem -text -noout
Certificate:
    Data:
        Version: 1 (0x0)
        Serial Number:
            52:0f:d4:a0:d1:41:ff:c7:2a:7e:96:f3:0e:6b:23:42:7d:77:66:e0
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C = ES, ST = Salamanca, L = Salamanca, O = SEGURIDAD DE SISTEMAS INFORMATICOS, OU = Practica 3 2024-2025,
 CN = Autoridad Cert Garcia_Martin_Garcia_Blanco, emailAddress = beetogm@usal.es
        Validity
            Not Before: Oct 25 10:44:40 2024 GMT
            Not After : Oct 23 10:44:40 2034 GMT
        Subject: C = ES, ST = Salamanca, L = Salamanca, O = usal, OU = seguridad, CN = localhost, emailAddress = beetogm@
usal.es
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
```

Como podemos comprobar se ha firmado correctamente, si observamos los valores de Issuer podemos verificar que son los mismos que los creados en la autorización de certificación del paso 1. Con esta comprobación ya podemos saber que se ha firmado correctamente.

PASO 3. CREACIÓN DE LOS CERTIFICADOS PERSONALES DE USUARIO.

Para empezar, generamos un par de claves privada y pública para el usuario:

openssl genrsa -out userkey.pem 2048

Y después, una solicitud de firma para el mismo:

openssl req -new -key userkey.pem -out usercsr.pem

```
alber@alber-VirtualBox:~$ openssl req -new -key userkey.pem -out usercsr.pem
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Salamanca
Locality Name (eg, city) []:Salamanca
Organization Name (eg, company) [Internet Widgits Pty Ltd]:usal
Organizational Unit Name (eg, section) []:seguridad
Common Name (e.g. server FQDN or YOUR name) []:70965216G
Email Address []:beetogm@usal.es

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:contra123%
An optional company name []:
```

Ahora firmaremos el CSR con la CA para generar con ello el certificado de usuario:

openssl x509 -req -in usercsr.pem -CA cert.pem -CAkey key.pem -CAcreateserial -out usercert.pem -days 3650 -sha256

```
alber@alber-VirtualBox:~$ openssl x509 -req -in usercsr.pem -CA cert.pem -CAkey key.pem -CAcreate
serial -out usercert.pem -days 3650 -sha256
Certificate request self-signature ok
subject=C = ES, ST = Salamanca, L = Salamanca, O = usal, OU = seguridad, CN = 70965216G, emailAdd
ress = beetogm@usal.es
```

Exportamos el certificado y la clave privada del usuario en formato pkcs12:

openssl pkcs12 -export -inkey userkey.pem -in usercert.pem -out usercert.p12 -name "Alberto García - 70965216G"

```
alber@alber-VirtualBox:~$ openssl pkcs12 -export -inkey userkey.pem -in usercert.pem -out usercer
t.p12 -name "Alberto García - 70965216G"
Enter Export Password:
Verifying - Enter Export Password:
alber@alber-VirtualBox:~$
```

Introducimos la contraseña de exportación y la conversión se habrá realizado correctamente.

En el caso de Unai se han seguido los mismos pasos:

```
unaigb@unaigb-VirtualBox:~/Escritorio/SSI$ openssl genrsa -out unai_privateKey.pem 2048
Generating RSA private key, 2048 bit long modulus (2 primes)
.....+++++
.....+++++
e is 65537 (0x010001)
```

```
unaigb@unaigb-VirtualBox:~/Escritorio/SSI$ openssl req -new -key unai_privateKey.pem -out unai_certifi
cate.pem
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Salamanca
Locality Name (eg, city) []:Salamanca
Organization Name (eg, company) [Internet Widgits Pty Ltd]:USAL
Organizational Unit Name (eg, section) []:SSI
Common Name (e.g. server FQDN or YOUR name) []:70915904G
Email Address []:unaigb@usal.es

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:contra123@
An optional company name []:
```

```
unaigb@unaigb-VirtualBox:~/Escritorio/SSI$ openssl x509 -req -in unai_certificate.pem -CA cert.pem -CA
key key.pem -CAcreateserial -out unai_certificate.pem -days 3650 -sha256
Signature ok
subject=C = ES, ST = Salamanca, L = Salamanca, O = USAL, OU = SSI, CN = 70915904G, emailAddress = unai
gb@usal.es
Getting CA Private Key
unaigb@unaigb-VirtualBox:~/Escritorio/SSI$ openssl pkcs12 -export -inkey unai_privateKey.pem -in unai_
certificate.pem -out unaiCertificado.p12 -name "Unai García - 70915904G"
Enter Export Password:
Verifying - Enter Export Password:
```

PASO 4. CONFIGURACIÓN DEL SERVIDOR WEB APACHE PARA HTTPS.

Vamos a comprobar primero que el módulo SSL de Apache está correctamente instalado:

sudo a2enmod ssl
sudo systemctl restart apache2

En nuestro caso no estaba instalado, por lo que instalaremos Apache2 y habilitaremos el módulo ssl.

sudo apt install apache2
sudo a2enmod ssl
systemctl restart apache2

A partir de aquí vamos a editar el fichero de configuración del sitio web. Vamos a comenzar dirigiéndonos a */etc/apache2/sites-available/default-ssl.conf* para añadir las siguientes líneas:

```
#   Enable/Disable SSL for this virtual host.
SSLEngine on

#   A self-signed (snakeoil) certificate can be created by installing
#   the ssl-cert package. See
#   /usr/share/doc/apache2/README.Debian.gz for more info.
#   If both key and certificate are stored in the same file, only the
#   SSLCertificateFile directive is needed.
SSLCertificateFile /home/alber/servercert.pem
SSLCertificateKeyFile /home/alber/serverkey.pem
SSLCACertificateFile /home/alber/cert.pem

<Directory /var/www/html>
Options Indexes FollowSymLinks
        AllowOverride All
        Require all granted
</Directory>

#   Server Certificate Chain:
```

Además, debemos de añadir nuestro certificado SSL con cada una de las rutas de nuestros certificados del servidor y añadir los permisos necesarios para poder ejecutar nuestro html.

Habilitamos SSL:

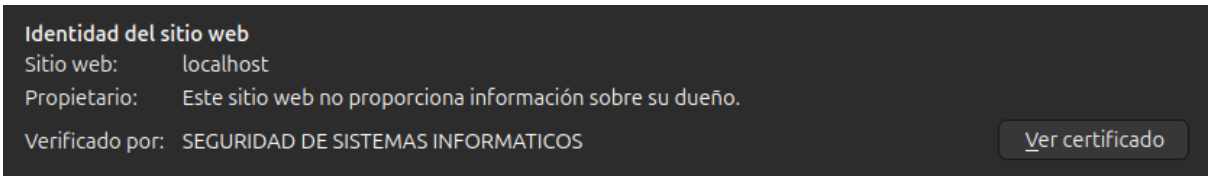
sudo a2ensite default-ssl.conf

Reiniciamos el servidor web y comprobamos que todo está correcto:

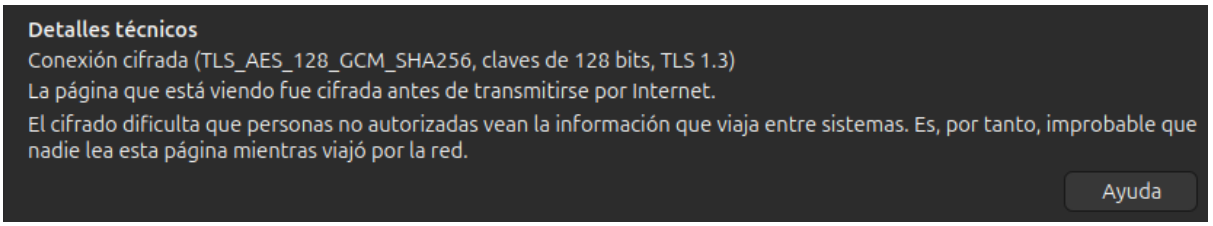
```
alber@alber-VirtualBox:/etc/apache2/sites-available$ sudo systemctl restart apache2
alber@alber-VirtualBox:/etc/apache2/sites-available$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
     Active: active (running) since Fri 2024-10-25 12:20:06 CEST; 2s ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 10871 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 10874 (apache2)
      Tasks: 55 (limit: 4615)
     Memory: 6.6M (peak: 6.9M)
        CPU: 41ms
     CGroup: /system.slice/apache2.service
             ├─10874 /usr/sbin/apache2 -k start
             ├─10875 /usr/sbin/apache2 -k start
             └─10877 /usr/sbin/apache2 -k start

oct 25 12:20:06 alber-VirtualBox systemd[1]: Starting apache2.service - The Apache HTTP Server...
oct 25 12:20:06 alber-VirtualBox apachectl[10873]: AH00558: apache2: Could not reliably determine the server>
oct 25 12:20:06 alber-VirtualBox systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-17/17 (END)
```

Ahora si iniciamos nuestro servidor web podremos comprobar que se ha verificado por la autoridad de certificación que habíamos creado previamente.



Además podremos comprobar que la conexión fue cifrada antes de entrar a ella:

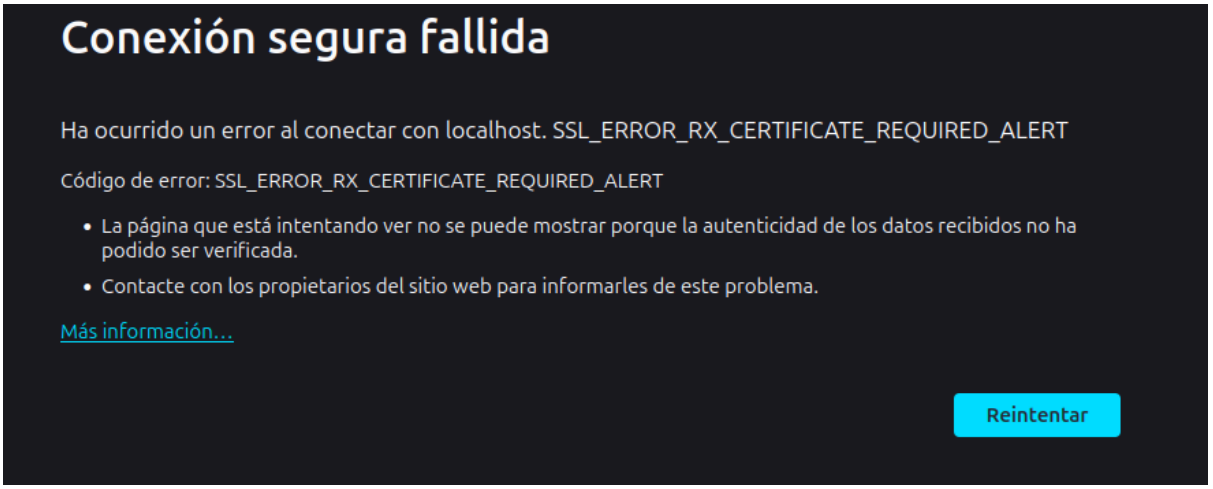


PASO 5 (OPCIONAL). AUTENTICACIÓN DE USUARIOS MEDIANTE CERTIFICADOS PERSONALES.

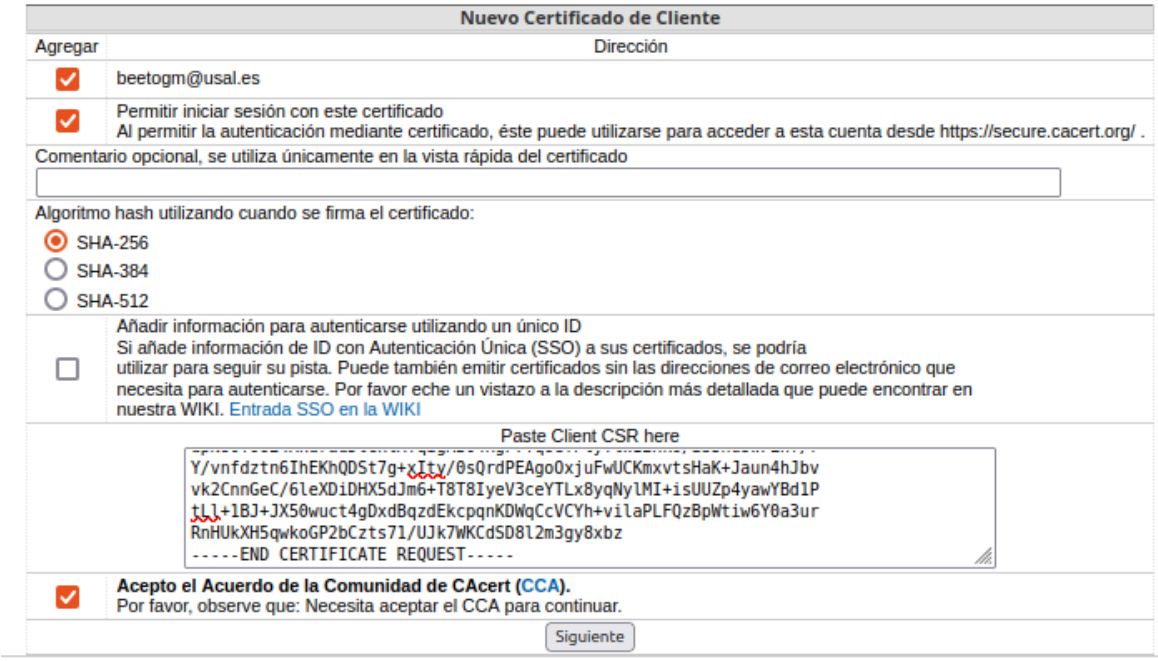
Si queremos configurar nuestro servidor para exigir certificados del cliente debemos de hacer lo siguiente, en el fichero de configuración del servidor seguro, añadimos las 2 primeras líneas siguientes líneas en el mismo archivo *default-ssl.conf:*

```
        SSLVerifyCLient require
        SSLVerifyDepth 10
```

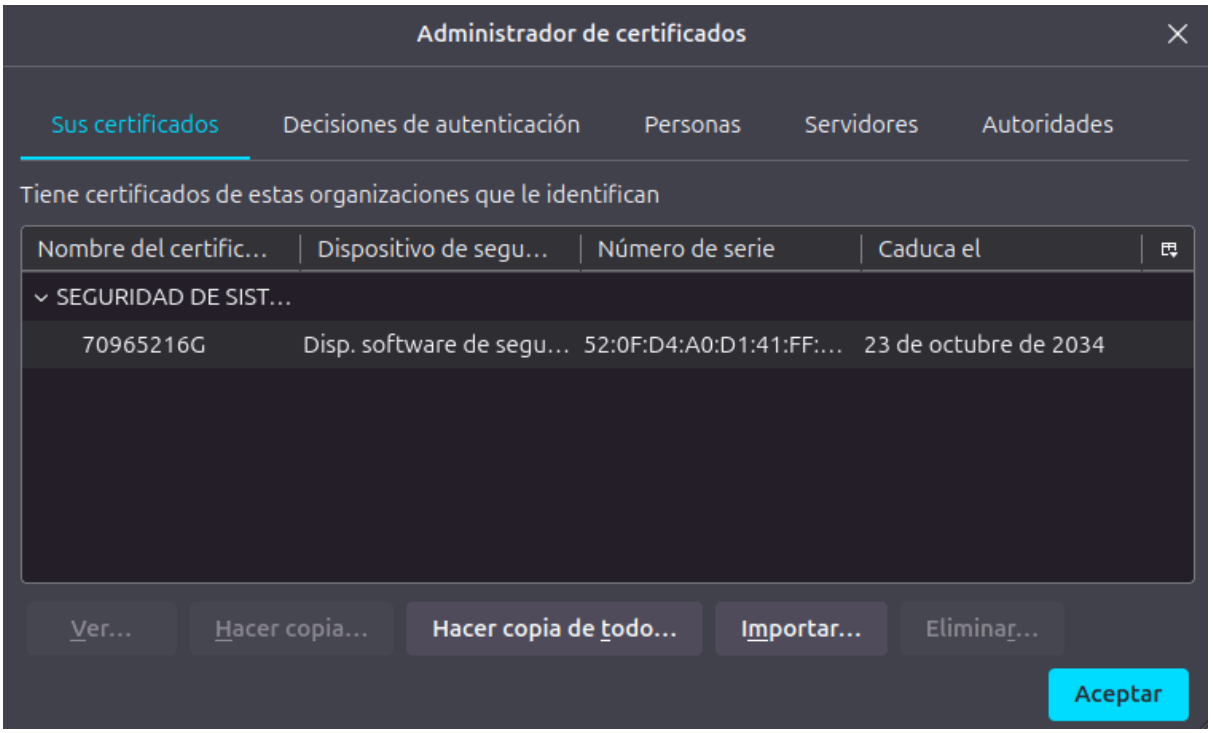
Ahora reiniciamos apache2, intentemos entrar de nuevo sin ninguna certificación:



Nos saldrá un error al intentar conectarnos ya que no disponemos de ningún certificado de cliente para el acceso seguro.
Vamos a solicitar uno en CAcert con nuestro .pem creado previamente en el paso 2:



Instalamos nuestro certificado .crt y lo importamos a nuestro navegador.

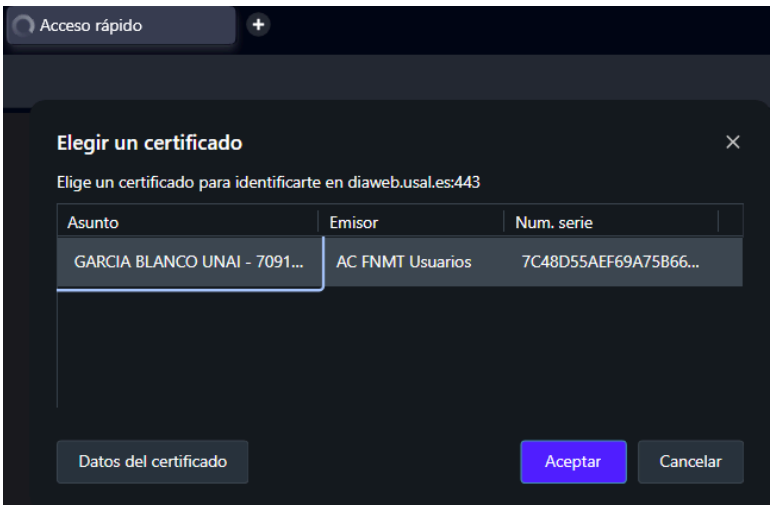


Ahora volvamos a intentar entrar en nuestra página web, como podemos ver, nos solicita un certificado de cliente, en nuestro caso el que hemos importado recientemente:



Aceptamos y podremos entrar de nuevo en nuestra página web correctamente.

Otro ejemplo es el acceso a diaweb, en este caso con el certificado de la FNMT como se muestra en la siguiente imagen:



La autenticación basada en un certificado digital funciona a través de un proceso de identificación y verificación criptográfica. En el caso de una página segura que utiliza un certificado, el proceso general sería el siguiente:

1. **Solicitud de conexión segura**: Al acceder a la página, el navegador establece una conexión segura (HTTPS) y envía al servidor un mensaje inicial indicando que quiere autenticarse usando un certificado digital.
2. **Solicitud del certificado del cliente**: El servidor responde solicitando el certificado digital del cliente, ya que quiere verificar la identidad del usuario.
3. **Selección del certificado**: El navegador del usuario presenta una lista de certificados disponibles (como el de la FNMT, DNIe o, en este caso, el de CAcert). El usuario selecciona el certificado apropiado para continuar.
4. **Firma del desafío**: El servidor envía un "desafío" (generalmente, un número aleatorio) que el navegador debe firmar usando la clave privada asociada al certificado. Esta clave privada está guardada de forma segura en el dispositivo del usuario y solo es accesible mediante su intervención, como una contraseña o PIN.
5. **Verificación de la autenticidad**: El servidor recibe la firma y usa la clave pública del certificado digital del usuario para verificar la firma. Si coincide, se autentica la identidad del usuario.
6. **Establecimiento de la conexión segura**: Una vez autenticado, se establece la conexión segura y el usuario puede interactuar con la página con su identidad validada.

Este proceso garantiza que el usuario es quien dice ser y que los datos transmitidos en la sesión están protegidos.

PASO 6. TRABAJANDO CON CURVAS ELÍPTICAS.

Vamos a repetir los pasos anteriores del apartado 2, pero usando algoritmos de estructuras elípticas. Comenzamos generando un par de claves ECC de 256 bits utilizando la curva prime256v1

openssl ecparam -name prime256v1 -genkey -noout -out servereccckey.pem
Creamos una solicitud de firma al igual que en los pasos anteriores:

openssl req -new -key servereccckey.pem -out servereccсsr.pem

```
alber@alber-VirtualBox:~$ openssl ecparam -name prime256v1 -genkey -noout -out servereccckey.pem
alber@alber-VirtualBox:~$ openssl req -new -key servereccckey.pem -out servereccсsr.pem
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Salamanca
Locality Name (eg, city) []:Salamanca
Organization Name (eg, company) [Internet Widgits Pty Ltd]:usal
Organizational Unit Name (eg, section) []:seguridad
Common Name (e.g. server FQDN or YOUR name) []:localhost
Email Address []:beetogm@usal.es

Please enter the following 'extra' attributes
to be sent with your certificate request
A challenge password []:contra123%
An optional company name []:
```

Firmamos el CSR ECC con el CA en formato x.509:

openssl x509 -req -in servereccсsr.pem -CA cert.pem -CAkey key.pem -CAcreateserial -out servereccсcert.pem -days 3650 -sha256

Configuramos apache con los nuevos certificados:

```
ano 7.2                                              default-ssl.conf *

#   SSL Engine Switch:
#   Enable/Disable SSL for this virtual host.
SSLEngine on

#   A self-signed (snakeoil) certificate can be created by installing
#   the ssl-cert package. See
#   /usr/share/doc/apache2/README.Debian.gz for more info.
#   If both key and certificate are stored in the same file, only the
#   SSLCertificateFile directive is needed.
SSLCertificateFile /home/alber/servereccсcert.pem
SSLCertificateKeyFile /home/alber/servereccckey.pem
SSLCACertificateFile /home/alber/cert.pem
```

Reiniciamos apache:

systemctl restart apache2

Entramos a nuestro servidor web y comprobamos que se está utilizando correctamente el algoritmo de curva elíptica:

